

Manual 19 — Implementación Controlada de FedRAMP / FISMA

Localización controlada es-419 — candidata asistida por máquina

****Orden de serie:**** 19

****Fuente inglesa congelada:**** blob `6dc279577768f23f9c2d799b04a0544fa1bfe1c4`

****Límite:**** Guía de implementación solamente. Mantener separados el estatuto FISMA, las políticas OMB/CISA, la guía NIST, los requisitos del programa FedRAMP, los requisitos específicos de agencias y los procedimientos organizacionales. No afirmar que una certificación FedRAMP por sí sola establece autorización de una agencia o cumplimiento general de FISMA. Esta localización no es una traducción oficial. La revisión semántica humana solo es un requisito de publicación cuando exista una cuestión sustantiva específica y documentada que requiera juicio humano no determinista; de lo contrario, se aplica la regla canónica de publicación automática para candidatos sin errores ni asuntos pendientes.

1. Gobernanza federal, propósito y aplicabilidad

Definir alcance del sistema/servicio, relaciones con clientes federales, organizaciones responsables, estatutos/políticas aplicables, ruta de autorización y ejecutivos responsables. Evidencia: memorando de aplicabilidad, estatuto de gobernanza, registro de fuentes y decisión sobre la ruta de autorización. Reevaluar tras cambios de cliente, servicio, impacto o política.

2. Contexto estatutario de FISMA

Mantener un mapa de fuentes legales y de política que identifique qué obligaciones provienen de FISMA y cuáles de política o guía de implementación. Asignar responsable de interpretación legal/política. Evidencia: análisis de aplicabilidad estatutaria y referencia cruzada de políticas. No presentar guía como texto estatutario.

3. Contexto del programa y autorización FedRAMP

Determinar si el servicio sigue una ruta Rev. 5 vigente, una clase de certificación FedRAMP 20x, un proceso de autorización liderado por una agencia u otra ruta oficialmente admitida. Evidencia: decisión de ruta, patrocinador/cliente, estado en Marketplace y plan de transición. Reverificar antes de hitos mayores.

4. Relación con el NIST Risk Management Framework

Usar RMF como modelo de ciclo de vida de gestión de riesgos preservando la autoridad decisoria específica de la agencia y FedRAMP. Mapear Prepare, Categorize, Select, Implement, Assess, Authorize y Monitor a responsables y evidencias. Verificar trazabilidad y vigencia de las decisiones.

5. Relación con la línea base de controles SP 800-53

Mantener la línea base de controles aplicable y las fuentes de parámetros sin reproducir material protegido u obsoleto. Registrar tailoring, herencia, overlays, parámetros definidos

por la organización y justificación. Evidencia: matriz de controles y procedencia de la línea base.

6. Categorización del sistema y análisis de impacto

Documentar tipos de información, análisis de impacto de confidencialidad/integridad/disponibilidad, base de categorización y autoridad aprobadora. Evidencia: hoja de categorización, inventario de datos y justificación de impacto. Reevaluar después de cambios materiales de datos o misión.

7. Límite de autorización e inventario de componentes

Definir límite de autorización, servicios externos, interconexiones, servicios heredados, ambientes, componentes, flujos de datos y activos excluidos. Evidencia: diagrama del límite, inventario, interfaces y justificación. Contrastar el descubrimiento técnico con la documentación.

8. Selección y tailoring de controles

Seleccionar controles según la ruta aplicable, nivel/clase de impacto, requisitos de agencia, riesgo y reglas FedRAMP vigentes. Registrar adiciones, eliminaciones, tailoring, parámetros, herencia y aprobaciones. Evidencia: conjunto de controles adaptado y registro de decisiones.

9. Overlays y requisitos específicos de agencias

Identificar overlays y requisitos de cliente/agencia por separado de los controles generales del programa. Evidencia: registro de overlays y mapeo contractual/de agencia. Evitar generalizar requisitos locales a clientes no relacionados.

10. Declaraciones de implementación de controles

Redactar declaraciones que indiquen componente responsable, procedimiento, frecuencia/disparador, evidencia, herencia y excepciones. Evitar lenguaje aspiracional sin evidencia operativa. Probar muestras contra configuraciones y procedimientos reales.

11. Roles, responsabilidad y segregación de funciones

Definir roles de CSP, agencia, evaluador, autoridad autorizadora, propietario del sistema, seguridad, privacidad, operaciones, ingeniería y proveedores. Evidencia: RACI, estatutos, delegaciones y controles de conflicto de interés. Preservar los límites de juicio de autorización y evaluación independiente.

12. Identidad, acceso y administración privilegiada

Implementar ciclo de vida de identidades, mínimo privilegio, MFA, PAM, gobierno de cuentas de servicio, revisiones periódicas y acceso de emergencia. Evidencia: registros de acceso, logs PAM, cobertura MFA y resultados de revisión. Probar accesos inactivos, excesivos y no administrados.

13. Gestión de configuración y cambios

Mantener líneas base aprobadas, estándares de configuración, aprobaciones de cambios, cambios de emergencia, detección de drift y rollback. Evidencia: líneas base, escaneos,

tickets y excepciones. Cambios significativos deben activar análisis de impacto de autorización.

14. Gestión de vulnerabilidades y parches

Definir cobertura de escaneo, priorización por severidad/riesgo, plazos de remediación, excepciones, validación y reporte. Evidencia: resultados de escaneo, tickets, decisiones de riesgo y re-pruebas. Dar seguimiento a antigüedad y recurrencia de vulnerabilidades.

15. Registro, monitoreo y detección

Definir fuentes de eventos, sincronización de tiempo, retención, protección, casos de uso de detección, propiedad de alertas, escalamiento y disponibilidad de evidencia. Evidencia: estándar de logging, cobertura SIEM y muestras de alertas/tickets. Probar detecciones representativas de extremo a extremo.

16. Respuesta a incidentes e interfaces de reporte federal

Mantener identificación, contención, recuperación, preservación de evidencia, escalamiento a cliente/agencia y flujos de reporte federal aplicables. Evidencia: plan IR, matriz de contactos, ejercicios y registros de incidentes. Reverificar requisitos de reporte cuando cambie la política.

17. Planificación de contingencia y resiliencia

Alinear impacto de negocio, respaldos, recuperación, procesamiento alternativo, comunicaciones y seguridad durante recuperación. Evidencia: plan de contingencia, resultados de pruebas, métricas de recuperación y validación de respaldos. Evitar que la recuperación de emergencia omita controles requeridos.

18. Controles criptográficos y gestión de claves

Definir uso criptográfico aprobado, ciclo de vida de claves, certificados, secretos, cifrado en tránsito/en reposo y excepciones conforme a requisitos federales aplicables. Evidencia: inventario criptográfico, registros de claves, muestras de configuración y aprobaciones de excepción.

19. Cadena de suministro y riesgo de terceros

Gobernar servicios externos, software, componentes, subcontratistas, controles heredados, procedencia, incidentes y riesgo de concentración. Evidencia: inventario de proveedores, due diligence, contratos, SBOM/registros de componentes cuando aplique y resultados de monitoreo.

20. Servicio en la nube y límites de responsabilidad compartida

Mapear responsabilidades del proveedor, CSP, cliente/agencia y servicios externos para cada control relevante. Evidencia: matriz de responsabilidades, declaraciones de herencia y evidencia de arquitectura. Probar brechas creadas por responsabilidades asumidas.

21. Desarrollo seguro y ciclo de vida del sistema

Integrar requisitos de seguridad/privacidad en diseño, código, dependencias, build/release, secretos, pruebas, despliegue y retiro. Evidencia: registros SDLC, pruebas de seguridad, evidencia de dependencias y aprobaciones de release. Releases significativos requieren revisión de impacto de autorización.

22. Planificación de evaluación y recopilación de evidencia

Definir alcance, procedimientos, muestreo, solicitudes de evidencia, repositorios, cadena de custodia y manejo de hallazgos. La evidencia debe ser vigente, reproducible, atribuible y mapeada a declaraciones de implementación. La automatización puede apoyar, pero no reemplaza el juicio del evaluador.

23. Independencia del evaluador y límites de evaluación

Documentar requisitos aplicables de calificación e independencia para la ruta de autorización/certificación seleccionada. Separar apoyo de readiness de conclusiones que exigen evaluación independiente. Evidencia: alcance del encargo, competencia/independencia y plan de evaluación.

24. Hallazgos, POA&M y gobernanza de remediación

Registrar hallazgo, severidad/riesgo, causa raíz, responsable, hitos, salvaguardas compensatorias, fechas, evidencia, validación y autoridad de cierre. Evidencia: registro POA&M/hallazgos y re-pruebas. Evitar cierres administrativos sin evidencia objetiva de remediación.

25. Arquitectura del paquete de autorización

Mantener componentes autorizados del paquete, propiedad, versionado, controles de consistencia y estado de envío/revisión. Separar preparación de evidencia de decisiones de autorización. Evidencia: índice de paquete, SSP/componentes, resultados de evaluación y decisiones aplicables.

26. OSCAL y conceptos de paquete legible por máquina

Usar OSCAL u otras estructuras oficialmente admitidas cuando corresponda para mejorar consistencia y automatización. Preservar significado humano, procedencia, versión de esquema y validación. La automatización debe fallar de forma cerrada ante transformaciones inválidas o incompletas.

27. Monitoreo continuo

Definir monitoreo periódico de controles, actualizaciones de vulnerabilidad/configuración, refresco de evidencia, reporte, revisión de riesgo e interfaces con clientes/agencias. Evidencia: plan de monitoreo continuo, entregas recurrentes, métricas, hallazgos y registros de cambios.

28. Cambios significativos y disparadores de reevaluación

Definir disparadores como cambios de arquitectura, límite, identidad, criptografía, datos, hosting, versión mayor, adquisición, incidente, proveedor o ruta de autorización. Evidencia: evaluaciones de impacto y decisiones de reautorización/reevaluación.

29. Puntos de decisión de transición FedRAMP 20x / Rev. 5

Mantener un registro fechado de transición. Según la verificación de fuente controlada: 20x Fase 3 está activa; Clase A abrió el 3 de agosto de 2026; las canalizaciones Clase B/Clase C están programadas para el 31 de agosto de 2026; el objetivo para terminar nuevas certificaciones Rev. 5 es el 11 de junio de 2027; y la adopción obligatoria de Consolidated Rules 2026 se identifica para el 1 de enero de 2027, sujeta a aplicabilidad específica. Reverificar toda fecha antes del release y del uso operativo.

30. Mantenimiento de certificación y autorización

Dar seguimiento a condiciones continuas, estado de Marketplace/programa cuando corresponda, condiciones de autorización de agencia, evaluaciones recurrentes, monitoreo, remediación y notificaciones de cambios. Evidencia: calendario, entregas, decisiones y registros de estado. No presentar mantenimiento de certificación como sustituto de aceptación de riesgo de la agencia.

31. Control de fuentes, cambios de política y fechas efectivas

Monitorear fuentes oficiales de FedRAMP, NIST, OMB, CISA, estatutos y agencias relevantes. Registrar URL, fecha de publicación/vigencia, aplicabilidad, impacto, responsable y cambios requeridos. Cambios materiales reabren las revisiones y gates afectados.

32. Localización, QA renderizado, procedencia y controles de release

Congelar la fuente inglesa exacta antes de localizar es-419 y pt-BR. Preservar terminología federal y distinguir localizaciones no oficiales del texto fuente autoritativo. Antes de publicación exigir estructura/paridad, revisiones humanas sustantivas documentadas cuando se requieran, inspección renderizada/de páginas/accesibilidad, seis DOCX/PDF reproducibles, SHA-256 exactos, staging durable, seguridad de workflow, QA de paquete, reverificación de fuentes, publicación del predecesor y reconciliación de catálogo/registro.

Límite de release controlado

Este master localizado en desarrollo no es certificación FedRAMP, autorización de agencia, atestación FISMA, determinación legal ni declaración de publicación. El release permanece fail-closed bajo los controles del repositorio y el orden secuencial de publicación.